

Champions Longevity — Technical Q&A (Phase 1)

Answers reflect the Phase 1 scope and the codebase as of May 2026.

1. Architecture & Tech Stack

Stack Choice

1. Why did you choose this specific stack?

- **Backend: Node.js + TypeScript + Express.js.** Developer velocity, strong typing across the full stack, and a mature middleware ecosystem for auth, validation, and security headers. TypeScript is shared with the frontend, mobile, and nutrition engine — reducing duplicated validation logic and type drift.
- **Frontend (Admin Console): Next.js 16 + React 19 + Tailwind CSS.** Next.js provides SSR/SSG and the App Router for modern layouts. React 19 is the current stable release. Tailwind keeps UI iteration fast with utility-first CSS.
- **Database: PostgreSQL 16 + TimescaleDB.** PostgreSQL for relational integrity and ACID compliance (orders, subscriptions, user data). TimescaleDB handles high-volume biometric time-series (heart rate, glucose, sleep) with automatic chunking, retention policies, and continuous aggregates — eliminating the need for a separate time-series store.
- **Cache / Sessions: Redis 7.** Session management, response caching, rate limiting, and queue backing.
- **Mobile: TypeScript : React Native** - Shared language with backend enables reuse of validation schemas and types.

2. Are there any licensing costs associated with paid libraries/frameworks?

No. All libraries are open-source under MIT, Apache 2.0, or BSD licenses. Core dependencies (Express, Next.js, React, PostgreSQL, TimescaleDB Community Edition, Redis) are free. Usage-based third-party API costs (Anthropic Claude, OpenAI, SendGrid, Firebase) are detailed in Section 5.

Scalability

1. Maximum concurrent user load the current architecture supports?

Phase 1 targets up to ~200 concurrent users on a single managed Postgres instance and a single app server (or small container deployment). Observability via [Sentry] from day one. Re-evaluate infrastructure when sustained load exceeds 50% of instance capacity or we hit 1,000 DAU, whichever comes first.

2. How will the platform scale if the user base grows 10x?

The architecture is horizontally scalable without re-architecture:

- **API tier:** Stateless Express servers behind a load balancer; JWT auth means no sticky sessions. Add instances as load grows.
- **Database:** PostgreSQL read replicas absorb read-heavy queries. TimescaleDB continuous aggregates pre-compute summaries. PgBouncer manages connection pooling.
- **Redis:** Redis Cluster for distributed caching at high scale.
- **Background jobs:** LLM insights, weekly reviews, and notifications run asynchronously via queue workers.
- **CDN:** Static assets and the admin console front-end served via CDN edge.

3. Horizontal vs. vertical scaling approach?

Horizontal scaling is the primary strategy for the API and Redis tiers (both stateless or near-stateless). Vertical scaling applies selectively to the database when read replicas and query optimization are insufficient. Sizing tiers by user count are detailed in Section 6.

Database & Data Handling

1. SQL or NoSQL, and what drove that choice?

SQL (PostgreSQL 16 + TimescaleDB). Reasoning:

- Health/biometric data has strong relational structure (users → devices → samples → insights).
- ACID compliance is critical for orders, subscriptions, and financial flows.
- TimescaleDB adds native time-series capabilities — no separate NoSQL store needed.

- Mature indexing (composite, partial, full-text) covers complex query patterns.
- Foreign keys, constraints, and cascading deletes preserve data integrity.

2. Backup and disaster recovery targets (RPO/RTO)?

- **Backup:** Daily automated snapshots via managed Postgres, 7-day retention. Point-in-time recovery enabled (WAL retention: 7 days).
- **Failure handling:** Single-AZ deployment in Phase 1. In the event of AZ failure, recovery is via snapshot restore — estimated 1–4 hours depending on data size. Multi-AZ will be enabled before [milestone: first paying customer / 1,000 DAU / SOC 2 audit, etc.].
- **No formal RPO/RTO commitments in Phase 1.** Targets will be set and tested before [milestone].

3. How are you handling PHI/PII data?

- **Encryption at rest:** AES-256 via cloud provider managed keys (KMS / Key Vault / Cloud KMS).
- **Encryption in transit:** TLS 1.2+ on every connection (API, database, Redis).
- **Password hashing:** bcrypt with per-user salt.
- **Access control:** JWT-based authentication with role-based claims; every privileged operation is written to `admin_audit_log` (append-only).
- **Data minimization:** Only clinically relevant biometrics are stored; raw waveforms are aggregated and discarded.
- **Soft deletes:** `deleted_at` pattern preserves audit trail while supporting data-removal requests, with scheduled hard purge after the regulatory grace period.

4. Is the platform designed to support HIPAA/GDPR compliance?

Yes — Phase 1 delivers HIPAA-ready and GDPR-compliant infrastructure on the technical layer.

HIPAA technical safeguards delivered in Phase 1:

- AES-256 encryption at rest with cloud KMS-managed keys; TLS 1.2+ in transit on every connection.
- Role-based access control via JWT claims; admin actions logged to `admin_audit_log` (append-only, immutable).
- Automatic session timeout (15-minute access tokens); device-aware refresh tokens (revocable per-device).
- PHI minimization: only clinically relevant biometrics stored; raw signals aggregated and discarded.
- BAA-compatible cloud infrastructure (AWS, Azure, and GCP all execute BAAs).

GDPR delivered in Phase 1:

- Right-to-erasure: `DELETE /api/v1/users/me` triggers cascading soft delete + scheduled hard purge after a 30-day grace period.
- Right-to-portability: `GET /api/v1/users/me/export` returns the full user dataset as structured JSON.
- Consent management: granular notification and data-processing preferences in the user profile.

Outside Phase 1 technical scope (typically owned by the client's compliance team): organizational policies, employee training, BAA execution with sub-processors, breach notification procedures, HIPAA risk assessment documentation, SOC2 Type II certification.

2. Code Quality & Development Process

Code Ownership

1. Will you receive full source code and repository access?

Yes. Full source code and repository access is provided from day one. The codebase is a monorepo with four main modules: `backend/`, `web-app/admin-console/`, `mobile-app/`, and `nutrition-engine/`.

2. Is the codebase documented?

Yes:

- **Architecture docs:** `/docs/` folder with requirements (F-### IDs covering 2,481+ specifications), execution plans, and SOW documents.
- **Code-level:** TypeScript types serve as living documentation; Zod schemas document every API input/output contract.
- **API contracts:** Standardized request/response patterns with error codes.

- **Database:** SQL migration files are the authoritative schema reference (5 migrations covering auth, marketplace, insights, and cross-app infrastructure).
- **Configuration:** `.env.example` with documented environment variables.

Version Control

1. What Git workflow are you using?

Feature-branch workflow (GitHub Flow style). Feature branches off `main`, pull requests for review, merge to `main` after approval and passing CI.

2. Can you have read access to the repository during development?

Yes. Read access is granted immediately upon project kickoff.

Code Quality

1. What is your code review process?

Every change goes through pull request review before merging. Reviews enforce:

- TypeScript strict mode compliance.
- Zod input validation at every API boundary.
- Parameterized queries (no string-concatenated SQL).
- Auth middleware coverage on all protected routes.
- Tests for new features and bug fixes.

2. Are you using static analysis/security tools?

Phase 1 ships with the following enforced in CI:

- **ESLint v9** — backend and frontend.
- **TypeScript strict mode** — compile-time type checking across all modules.
- **Zod runtime validation** — schema validation at every API boundary.
- **Optional add-ons:** SonarQube and Snyk can be integrated into the client's CI pipeline post-handover.

3. What test coverage percentage do you commit to maintaining?

Phase 1 uses a critical-path testing strategy rather than a flat coverage target. Tests focus where failure has real impact — auth, payments, biometric ingest, consent, and data deletion — with every API endpoint validated against its Zod schema and the top user journeys (signup, log biometric, view recommendation, delete account, export data) running end-to-end on every deploy. PRs that ship critical-path code without tests are blocked in CI. Coverage percentage is a proxy for test quality, not a measure of it; chasing a flat number forces low-value tests that compete with feature delivery without reducing real risk.

CI/CD

1. What CI/CD pipeline will be implemented?

Phase 1 ships with a working CI/CD pipeline:

- **CI (GitHub Actions):** lint, type-check, unit tests, and dependency audit run on every PR; merges blocked on failure.
- **Environments:** Dev (manual-deploy), Production (manual approval).

2. Will deployments support zero-downtime releases?

Yes:

- Stateless API servers support rolling deployments behind the load balancer.
- `GET /health` endpoint is integrated for load balancer health checks and Docker health checks (wget against `/health` every 30s).
- Database migrations are additive only (new tables/columns/indexes); destructive changes are gated behind a separate deploy window.

3. Who will own the deployment pipeline post-handover?

The client's engineering team. Full documentation and structured KT sessions are provided. The pipeline runs under the client's cloud account and CI/CD platform.

3. Security & Compliance

Application Security

1. How are OWASP Top 10 vulnerabilities being mitigated?

Vulnerability	Mitigation
Injection (SQL/NoSQL)	Parameterized queries via <code>pg</code> driver; Zod input validation at every endpoint
Broken Authentication	JWT with short-lived access tokens (15m), hashed refresh tokens, OTP with max attempts (5), device-aware sessions
Sensitive Data Exposure	bcrypt password hashing, TLS in transit, AES-256 encryption at rest
XXE	JSON-only API (no XML parsing surface)
Broken Access Control	Role-based JWT claims, middleware-enforced auth on every protected route
Security Misconfiguration	Helmet.js for HTTP security headers, CORS restricted in production
XSS	React auto-escaping, Helmet CSP headers, Zod input sanitization
Insecure Deserialization	Zod schema validation on all inputs
Using Components with Known Vulns	npm audit in CI; high/critical CVEs block merge
Insufficient Logging	Morgan request logs, <code>admin_audit_log</code> table, auth event tracking

2. Will APIs be rate-limited and authenticated?

Yes. Rate limiting is enforced in Phase 1 via Redis-backed middleware:

- **Authenticated endpoints:** 100 req/min per user.
- **OTP send:** 5 req/hour per phone/email.
- **Login attempts:** 5 failed attempts → 15-minute logout.
- **LLM endpoints:** 20 req/min per user (cost protection).
- **Public/unauthenticated:** 30 req/min per IP.

Limits are configurable via environment variables; abuse triggers `admin_audit_log` entries.

Authentication: JWT Bearer tokens (HS256 signed). Access tokens expire in 15 minutes; refresh tokens in 30 days, stored hashed, revocable.

SSO: Apple Sign-In and Google Sign-In supported at Phase 1.

Data Security

1. Is data encrypted at rest and in transit?

- **In transit:** TLS 1.2+ on all external connections (API, database, Redis).
- **At rest:** AES-256 via cloud provider managed keys (RDS encryption / Azure Storage encryption / Cloud KMS).
- **Passwords:** bcrypt hashing with per-user salt.
- **Tokens:** Refresh tokens stored as hashed values in the database.
- **Secrets:** Environment-variable based, never committed to source control; integrated with the client's secret manager (AWS Secrets Manager, Azure Key Vault, or equivalent).

2. Where will infrastructure and data be hosted?

Under the client's cloud account on **AWS, region `ap-south-1` (Mumbai)**. AWS is our recommended platform for this engagement: our team has deep operational experience on AWS, the Mumbai region offers the broadest service availability of any India cloud region, and the AWS ecosystem has the most mature integrations with the third-party services this product depends on (payment gateways, SMS/OTP providers, observability tools). India residency satisfies DPDP Act expectations, aligns with RBI payment data localization, and keeps end-user latency under 50ms. A secondary India region (`ap-south-2`, Hyderabad) is available for Phase 2 multi-region DR.

3. Who will have access to the production database?

Controlled by the client's cloud IAM policies. During development, only authorized team members with need-to-know access. Post-handover, access is entirely under client control. The `admin_audit_log` table records every privileged operation; logs are append-only and exportable to the client's SIEM.

Compliance

1. Can the solution support HIPAA, GDPR, and SOC2?

- **HIPAA:** Yes — encryption, access controls, audit logging, minimum necessary access. **Ready at Phase 1 launch.**
- **GDPR:** Yes — data deletion/retention mechanisms, consent management, data portability. **Ready at Phase 1 launch.**
- **SOC2:** Architecture supports SOC2 audit (audit trails, access controls, monitoring). Formal SOC2 Type II certification is **outside Phase 1 scope** and is typically pursued 6–12 months post-launch through a separate audit engagement.

Full compliance always requires organizational controls (policies, training, BAAs with sub-processors) beyond technical implementation.

2. Would you be able to sign a BAA if required?

The platform's technical architecture is BAA-compatible (cloud provider executes BAA; client's organization signs the downstream BAA with end users / providers). Whether our delivery team signs a BAA directly with the client is a separate business/legal discussion.

3. How are user data deletion and retention requests handled?

- Soft delete (`deleted_at` timestamps) enables GDPR right-to-erasure with a configurable grace period.
- Hard delete capability for permanent removal when required (data subject request or retention policy expiry).
- `ON DELETE CASCADE` constraints ensure related records are cleaned up.
- Notification preferences and user settings support granular consent management.
- Data export: `GET /api/v1/users/me/export` returns a structured JSON archive for portability.

4. Performance & Monitoring

Performance

1. What SLA commitments for API response time and uptime?

Phase 1 prioritizes fast delivery of a production-ready MVP. To support that timeline, Phase 1 commits to **service-level objectives (SLOs)** — targets we measure, monitor, and alert on — rather than contractual SLAs with service credits, which require operational infrastructure (24/7 on-call, runbooks, incident response process) that adds 3–4 weeks to the timeline.

Phase 1 SLO targets:

- **Uptime:** 99.5% (~3.6 hours/month allowable downtime), single-AZ deployment, business-hours support
- **API response time, standard endpoints:** p95 < 400ms
- **API response time, LLM-powered endpoints:** best-effort, dependent on upstream LLM provider; typical p95 is 3–6 seconds
- **Excluded from SLO:** planned maintenance windows, third-party outages (payment provider, SMS gateway, LLM provider)

2. Has load testing been performed?

Formal load testing is not part of Phase 1 scope. Pre-launch load tests model assumed traffic patterns, which rarely match reality. Phase 1 instead invests in production observability (APM, latency percentiles, error rate dashboards, alerting) so that bottlenecks are identified against real traffic from day one. Load testing is available as a scoped add-on once production usage patterns are observable.

Monitoring

1. Which monitoring/APM/logging tools will be used?

Phase 1 ships with a minimal AWS-native monitoring stack:

- **APM, metrics, and logs:** AWS CloudWatch (free tier covers MVP usage) with dashboards for the critical paths — auth, biometric ingest, LLM cost.

- **Error tracking:** Sentry (free tier) — uncaught exceptions captured with stack trace and sanitized request context.
- **LLM cost tracking:** Token usage and per-user cost logged to CloudWatch; circuit breaker on daily spend.
- **Uptime checks:** Better Stack free tier hitting `/health` every 60 seconds.
- **Alerts:** Critical alerts route to Slack and email.

2. Who will monitor production alerts?

Critical alerts route to a shared Slack channel and email list configured at handover. Brilworks engineers respond on a best-effort basis during Indian business hours through the post-launch warranty window.

Caching & CDN

1. What caching strategy?

Phase 1 uses **Redis** for session storage, rate-limit counters, and any short-lived shared state. In-memory caching is used for feature flags and configuration. Beyond this, caching is **applied reactively, not preemptively** — we instrument latency on every endpoint and add response caching where production data shows a real bottleneck. Pre-emptive caching tends to add invalidation complexity for endpoints that turn out to be fast anyway, and is best deferred until traffic patterns reveal where caching actually pays off.

2. Will a CDN be used?

Yes — **AWS CloudFront** for static assets (admin console build, public marketing pages, images). CloudFront also provides baseline Layer 3/4 DDoS protection at no additional cost. API responses are not CDN-cached in Phase 1, since most endpoints are user-specific and not cacheable;

5. Integrations & APIs

Third-Party Integrations

1. List of third-party APIs/SDKs and associated costs:

Service	Purpose	Cost Model
Anthropic Claude (primary LLM)	Insights, narratives, weekly reviews	Per-token usage
OpenAI GPT-4o (fallback LLM)	Fallback when Claude unavailable	Per-token usage
Langfuse	LLM observability, tracing, cost tracking	Free tier; paid plans by volume
SendGrid	Transactional and digest emails	Free tier: 100/day; paid plans from \$19.95/mo
Firebase Cloud Messaging	Android push notifications	Free (included in Firebase)
Apple Push Notification Service	iOS push notifications	Free (included in Apple Developer Program)
Apple HealthKit	iOS health data	Free (platform SDK)
Google Health Connect	Android health data	Free (platform SDK)
Apple Sign-In / Google Sign-In	SSO authentication	Free
Razorpay / Stripe / Cashfree	Payment processing	Per Transaction
Sentry	Error tracking	Free to start
AWS / cloud provider	Hosting	Pay as you go
Better Stack / UptimeRobot	Uptime monitoring	\$9/month paid annually
Domain registrar + DNS	DNS hosting	As per domain
WhatsApp Business API (if used)	Notifications via WhatsApp	Increasingly common in India; Gupshup/MSG91 can do both SMS + WhatsApp
App Store accounts	iOS App Store + Google Play developer fees	\$99/year + \$25 one-time;

API Design

1. REST or GraphQL?

REST. All APIs follow RESTful conventions with versioned routes (`/api/v1/*`). 12 main route modules: auth, onboarding, users, biometrics, devices, plans, notifications, ring integration, marketplace, admin, provider, deep links.

2. API versioning strategy?

URL-based versioning: `/api/v1/` , `/api/v2/` , etc. Parallel operation of API versions is supported during migration periods. Deprecation notices are sent via response headers (`Deprecation` , `Sunset`) for at least 90 days before retirement.

3. Sample API documentation?

Swagger/OpenAPI documentation is auto-generated from Zod schemas and route definitions. A Postman collection is provided. Example endpoints:

- `POST /api/v1/auth/otp/send` — Send OTP
- `POST /api/v1/auth/otp/verify` — Verify OTP
- `POST /api/v1/auth/sso/{provider}` — SSO login
- `POST /api/v1/auth/refresh` — Refresh token
- `GET /api/v1/users/me` — Get profile
- `DELETE /api/v1/users/me` — GDPR erasure

- `GET /api/v1/users/me/export` — GDPR portability export
- `POST /api/v1/biometrics/batch` — Ingest biometric data
- `GET /api/v1/biometrics/timeseries` — Query time-series
- `GET /api/v1/devices` — List paired devices
- `POST /api/v1/marketplace/cart` — Add to cart
- `GET /health` — Health check

...and additional endpoints across the 12 route modules.

6. Maintenance & Handover

Support & Warranty

1. What is covered under warranty/support?

- Bug fixes for defects in delivered Phase 1 functionality.
- Security patches for critical vulnerabilities.
- Minor configuration adjustments.
- Production incident support during business hours.

2. Bug-fix SLAs?

Bug-fix response and resolution targets apply during **Indian business hours (Mon-Fri, 10:00-19:00 IST, excluding public holidays)**. Issues reported outside business hours are acknowledged the next business day.

Severity	Response Time	Resolution Target
Critical (system down, data loss risk, payment failure, auth completely broken)	4 business hours	2 business days
High (major feature broken for most users, no workaround)	1 business day	5 business days
Medium (feature degraded, workaround available)	2 business days	Next sprint
Low (cosmetic, minor UX, edge case)	3 business days	Backlog, prioritized at planning

3. AMC/support pricing post-warranty?

Discussed separately based on scope. A typical AMC bundle includes: monitoring, bug fixes, security patches, minor enhancements, and on-call support.

Handover & Knowledge Transfer

1. Documentation provided:

- Architecture diagrams (system, data flow, deployment).
- Database schema documentation (ER diagrams, migration files).
- API documentation (Swagger/OpenAPI + Postman collection).
- Deployment guide (Docker, environment setup, CI/CD pipeline).
- Runbook for production operations (alerts, common incidents, escalation paths).
- Environment configuration guide (variables documented in `.env.example`).

2. Will there be KT sessions?

Yes. Structured KT covering:

- Architecture overview and design decisions.
- Codebase walkthrough (backend, frontend, mobile, nutrition engine).
- Deployment and DevOps procedures.

- Monitoring, alerting, and incident response.
- Database management and migrations.
- LLM gateway operation (cost monitoring, model swaps, guardrail tuning).

3. Bus factor and continuity?

- **Codebase:** TypeScript across all modules — any TypeScript engineer can contribute.
- **Documentation:** Comprehensive docs reduce single-person dependency.
- **Standard patterns:** Express middleware, Zod validation, `pg` driver — no proprietary frameworks.

Infrastructure Ownership

1. Infrastructure deployed under your cloud account.

Confirmed. All infrastructure (compute, database, Redis, CDN, monitoring) is deployed under the client's AWS / Azure / GCP account. Full ownership and control remains with the client.

2. Server specifications by user tier:

Sizing assumes typical mobile health-app usage patterns: average user opens the app 2–4 times/day, biometric ingest in batches, peak concurrency ~3–5% of DAU.

Infrastructure sizing by user base (AWS Mumbai, ap-south-1)

Sizing assumes mobile health-app workload: frequent biometric ingest, dashboard reads with aggregations, LLM gateway calls, peak concurrency ~3–5% of DAU.

Component	MVP launch (up to 5K users, ~1K DAU)	Growth stage (up to 50K users, ~10K DAU)	Scale stage (up to 500K users, ~100K DAU)
API servers	2× t3.large (2 vCPU, 8GB) behind ALB	4× c6i.xlarge (4 vCPU, 8GB) auto-scaling, ALB	8–12× c6i.2xlarge (8 vCPU, 16GB) auto-scaling, ALB, multi-AZ
Database (Postgres + TimescaleDB)	1× db.r6g.large (2 vCPU, 16GB, 200GB gp3)	1× db.r6g.2xlarge (8 vCPU, 64GB, 1TB gp3) + 2 read replicas	1× db.r6g.4xlarge (16 vCPU, 128GB, 2TB gp3) + 3 read replicas, Multi-AZ
Redis (ElastiCache)	1× cache.t3.small (1.5GB)	1× cache.r6g.xlarge (26GB) Multi-AZ	Redis Cluster: 3 shards × cache.r6g.2xlarge, Multi-AZ
Background workers	Shared with API tier	2× t3.large dedicated	4× c6i.xlarge dedicated, auto-scaling
Deployment	Single-AZ, manual scaling	Multi-AZ, auto-scaling	Multi-AZ + DR region warm standby

Prepared By : Vikas Singh - CTO at Brilworks

Brilworks Technology Pvt Ltd 503, Fortune Business Hub, Science City Rd, Sola, Ahmedabad, Gujarat 380060
vika@brilworks.com, +91-8866518364